

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

一、選擇題

答案	題目
B	1. 某關鍵基礎設施提供者（CIP）在進行 ISO/IEC 27001:2022 轉版時，針對新增的「威脅情資（Threat Intelligence）」控制項進行規劃。在滿足《資通安全管理法》要求的前提下，下列何種做法最能體現該控制項的實務價值？ (A) 建立專屬情資資料庫，要求所有維運人員每日手動比對惡意網址 (B) 將收集到的威脅情資整合至現有的防火牆與端點防禦系統，實現自動化阻斷 (C) 定期下載國家資安資訊分享與分析中心（N-ISAC）的警訊通報並存檔備查 (D) 委託第三方顧問公司每年產出一次全球資安威脅趨勢報告，呈報至資安委員會
D	2. 在建立資訊安全管理系統（ISMS）的有效性指標（KPI）時，資安架構師正針對「零信任架構（ZTA）」的導入成效進行設計。考量到「身分鑑別繞過（Authentication Bypass）」，下列何項最能反映組織在面對身份攻擊時的真實防禦有效性？ (A) 每年進行資安意識訓練的員工總時數 (B) 「平均偵測時間（MTTD）」與「平均應變時間（MTTR）」在身份威脅偵測與反應（ITDR）情境下的變動趨勢 (C) 每月封鎖的惡意 IP 數量與防火牆攔截率之總和 (D) 組織內達成多因子驗證（MFA）部署的伺服器百分比
C	3. 企業正在導入 ISO 27017 雲端服務資訊安全控制指引。資安團隊在設計雲端控制措施時，發現不同服務模式（IaaS/PaaS/SaaS）的權責不清是最大風險來源。為了確保供應鏈安全與法規遵循的有效性，下列何項行動被視為設計所有雲端安全控制措施的邏輯前提與基礎？ (A) 直接採用雲端供應商提供的 SOC 2 Type II 或 ISO 27001 證書，並將其視為完全免除內部風險評估責任的依據 (B) 在服務級別協議（SLA）中強制要求擁有對雲端資料中心進行無預警實地實體稽核（On-site Physical Audit）的權利 (C) 依據所選用的服務模式（IaaS/PaaS/SaaS），詳細釐清並對照雙方的「責任分擔模型（Shared Responsibility Model）」，識別企業端應負責的控制剩餘風險 (D) 基於法規遵循考量，制定策略完全禁止任何含有個人可識別資訊（PII）的資料上傳至公有雲，以消除資料主權風險

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
ACD	4. 一個完整的供應鏈風險管理計畫，不僅僅是要求供應商填寫一份安全問卷。下列哪些措施能顯著提升第三方風險管理的有效性？（複選） (A) 在合約中明確訂定詳細的資訊安全責任、稽核權利與事件通報要求 (B) 完全信任大型或知名的供應商，並豁免其安全審查流程 (C) 要求所有供應商提供其完整的軟體物料清單（Software Bill of Materials, SBOM） (D) 定期利用外部攻擊面管理（EASM）工具，主動掃描和評估供應商的對外安全狀態
B	5. 【題組 1】情境如附圖所示。在導入生成式 AI 客服系統的規劃階段（Plan），依據 ISO 27001:2022 條款 6.1.2（資訊安全風險評鑑）之要求，下列何項作為最符合風險導向的邏輯順序？ 「A 金融科技」是一家提供 SaaS 服務的支付公司，已通過 ISO 27001:2022 認證。為因應 2025 年的業務擴張，公司決定將核心交易系統從地端遷移至公有雲環境，並計畫引入生成式 AI 優化客戶客服系統。然而，近期供應鏈攻擊頻傳，且歐盟 GDPR 與國內《個資法》對於 AI 自動化決策的規範日益嚴格。資安長要求資安工程團隊重新檢視現有的資訊安全管理系統（ISMS），確保在導入新技術的同時，維持合規性並有效控管風險。 (A) 立即購買 AI 資安防護軟體，並強制所有開發人員安裝以確保開發環境安全 (B) 識別導入 AI 可能帶來的資產弱點與威脅，評估其對機密性、完整性及可用性的潛在衝擊，再決定處置選項 (C) 直接修訂「適用性聲明書（SoA）」，將所有與 AI 相關的控制措施列為排除項目 (D) 先完成 AI 系統的程式碼開發，待上線前再進行滲透測試以驗證安全性

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
C	6. 【題組 1】情境如附圖所示。針對公有雲遷移案，供應商管理是關鍵一環。依據 ISO 27001:2022 附錄 A 控制措施 5.23（使用雲端服務之資訊安全），在與雲端服務提供者（CSP）簽訂合約時，下列何項策略最能展現「責任分擔模型」的實務應用？ 「A 金融科技」是一家提供 SaaS 服務的支付公司，已通過 ISO 27001:2022 認證。為因應 2025 年的業務擴張，公司決定將核心交易系統從地端遷移至公有雲環境，並計畫引入生成式 AI 優化客戶客服系統。然而，近期供應鏈攻擊頻傳，且歐盟 GDPR 與國內《個資法》對於 AI 自動化決策的規範日益嚴格。資安長要求資安工程團隊重新檢視現有的資訊安全管理系統（ISMS），確保在導入新技術的同時，維持合規性並有效控管風險。 (A) 確認 CSP 擁有效的 ISO 27001 證書，即可免除我方對雲端組態設定的稽核責任 (B) 為了節省成本，直接採用 CSP 提供的預設合約，不進行任何額外的資安條款增補或審閱 (C) 於合約中明確定義雙方的資安責任邊界，並要求 CSP 提供預設的安全組態功能及定期的第三方稽核報告 (D) 要求 CSP 對所有資安事件負完全責任，包括客戶端應用程式的漏洞修補與權限設定
D	7. 【題組 1】情境如附圖所示。情境中提到公司將使用 AI 分析客戶交易資料。若行銷部門希望將舊有的歷史交易資料用於訓練 AI 模型以進行精準行銷，依據隱私保護原則與合規要求，下列何項建議最為適當？ 「A 金融科技」是一家提供 SaaS 服務的支付公司，已通過 ISO 27001:2022 認證。為因應 2025 年的業務擴張，公司決定將核心交易系統從地端遷移至公有雲環境，並計畫引入生成式 AI 優化客戶客服系統。然而，近期供應鏈攻擊頻傳，且歐盟 GDPR 與國內《個資法》對於 AI 自動化決策的規範日益嚴格。資安長要求資安工程團隊重新檢視現有的資訊安全管理系統（ISMS），確保在導入新技術的同時，維持合規性並有效控管風險。 (A) 在官方網站更新隱私權政策，聲明公司有權使用歷史資料，即具有法律回溯效力 (B) 資料存放在公司內部伺服器，屬內部利用，無需進行任何處理即可直接投入訓練 (C) 將客戶姓名的欄位進行遮蔽（Masking），即可視為非個資並自由使用於任何目的 (D) 確認原始蒐集目的之同意範圍，若不符則需進行去識別化（De-identification）至無法回溯特定個人，或重新取得當事人同意

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
ABC	8. 【題組 1】情境如附圖所示。面對 2025 年日益猖獗的供應鏈勒索軟體攻擊，為了強化 ISMS 的韌性並符合 ISO 27001:2022 新增控制措施的精神，下列哪些技術或管理措施應納入優先實施計畫？（複選） 「A 金融科技」是一家提供 SaaS 服務的支付公司，已通過 ISO 27001:2022 認證。為因應 2025 年的業務擴張，公司決定將核心交易系統從地端遷移至公有雲環境，並計畫引入生成式 AI 優化客戶客服系統。然而，近期供應鏈攻擊頻傳，且歐盟 GDPR 與國內《個資法》對於 AI 自動化決策的規範日益嚴格。資安長要求資安工程團隊重新檢視現有的資訊安全管理系統（ISMS），確保在導入新技術的同時，維持合規性並有效控管風險。 (A) 建立威脅情資（Threat Intelligence）機制，收集並分析與金融產業相關的供應鏈攻擊手法（TTPs） (B) 導入資料外洩防護（DLP）與資料遮罩技術，確保即便系統遭入侵，敏感受保護資料（PII）仍受保護 (C) 針對 ICT 供應鏈實施嚴格的變更管理，要求供應商在軟體更新前提供軟體物料清單（SBOM）以檢視潛在漏洞 (D) 禁止所有雲服務供應商透過遠端連線進行維護，一律要求現場作業
A	9. 如附圖所示。某公司人資部門建立了一個線上系統，提供部門主管審核新進員工之個人資料與合約內容。為了避免資料外洩，該系統之存取控制需求設計如附圖所示。請問依據該系統之需求，最適合採用下列哪一種存取控制機制？ - 每位主管只能存取自己所屬部門員工之資料 - 系統管理員定義了「部門主管」與「人資專員」兩種角色，各自擁有不同權限，使用者需被指派角色後才能操作 - 若主管調任至其他部門，系統將自動移除原有角色，並重新賦予新角色以反映新職務權限 - 主管無法自行更改權限或轉讓給其他員工 (A) 角色式存取控制（Role-Based Access Control, RBAC） (B) 自由選定存取控制（Discretionary Access Control, DAC） (C) 強制存取控制（Mandatory Access Control, MAC） (D) 階層式存取控制（Hierarchical Access Control）

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
A	10. 面對混合雲環境下的特權帳號管理（PAM）挑戰，為減少攻擊面並落實「最小權限原則」，針對雲端管理員的高權限存取需求，下列何項機制最為適切？ (A) 導入即時存取機制，管理員需經申請核可後，動態賦予具時效性的臨時權限，任務結束後自動回收 (B) 共用一組最高權限的 Root 帳號，將密碼拆分由兩人保管，僅在緊急事故時組合使用 (C) 為每位管理員建立獨立且永久有效的雲端 IAM Admin 帳號，並啟用多因子驗證（MFA） (D) 限制管理員僅能透過公司內部的特定 IP 位址登入雲端控制台，不需額外限制權限範圍
C	11. 某家大型企業正進行數位轉型，計畫將核心客戶資料移轉至雲端環境，並重新規劃內部網路的存取控制架構。資安團隊在設計「存取控制模型」與「網路存取控制（NAC）」架構時，考量到縱深防禦與職務區隔原則，針對敏感資產的存取權限管理，下列何種規劃方案在實務操作與風險控管上表現最為適切？ (A) 實施去中心化的身分驗證架構，讓各部門主管自行管理資源的存取權限，並透過每季一次的權限稽核，確保職務區隔原則受到落實 (B) 採行嚴格的強制存取控制（MAC）模型，將所有員工的角色權限固定於資料庫，並限制任何非 IT 管理員身分者進行網路連線，以消除人為權限操作風險 (C) 導入基於屬性的存取控制（ABAC）模型，結合動態 NAC 驗證機制，根據使用者的角色、裝置合規性與存取時間等變數，動態決策授權範圍 (D) 建立以角色為基礎的存取控制（RBAC）模型，並將所有網路連線請求強制導向黑名單過濾機制，確保已知的高風險惡意 IP 與 MAC 位址無法進入核心區域
CD	12. 在當前的地緣政治背景下，國家級駭客組織針對特定企業的網路攻擊日益頻繁。企業為了應對此類高階威脅，應採取下列哪些準備措施？（複選） (A) 將所有伺服器重新命名為與功能相關的代號 (B) 要求配置威脅獵捕（Threat Hunting）團隊，每位資安人員皆須具備威脅獵捕相關專業 (C) 積極訂閱並整合高品質的威脅情資（Threat Intelligence）饋送 (D) 制定並演練針對破壞性攻擊（如資料清除 Wiper）的災難恢復計畫

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
D	13. 【題組 2】情境如附圖所示，在這次大規模的內部網路架構調整中，為了防止維運人員濫用權限，團隊計畫在管理流程中實施內部控制。下列哪一項措施最能符合此安全管理原則？ 「飛遜科技股份有限公司」目前正進行一項大規模的內部網路架構調整。為了因應企業數位轉型並強化整體資安防禦能力，資安團隊必須針對新一代的內部網路環境、系統存取、密碼管理與人員權限進行全面的重新規劃與防護升級。調整範圍涵蓋了資訊機房、核心資通系統、資安防護設備以及網路監控設備。 (A) 由網路維運主管提出並執行設備設定變更，完成後再依變更申請內容自行確認設定結果與紀錄完整性 (B) 由維護工程師先依作業需求完成設備設定，之後由別組高階主管覆核作業程序，並以覆核紀錄作為變更核准依據 (C) 由維護工程師使用共用特權帳號執行核准變更，再透過登入來源位址、操作時間及設備日誌追蹤執行責任 (D) 由維護工程師依核准的變更申請執行系統設定，變更內容的審查與核准則由未參與執行的權責角色負責

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
A	14. 【題組 2】情境如附圖所示，配合內部網路架構調整，「飛遜科技股份有限公司」在部署新的資安防護設備與機房規劃時，導入了多層次防護的觀念。在防範外部駭客或未授權人員惡意存取核心資通系統的情境下，下列哪一個組合最無法展現此安全架構的做法？ 「飛遜科技股份有限公司」目前正進行一項大規模的內部網路架構調整。為了因應企業數位轉型並強化整體資安防禦能力，資安團隊必須針對新一代的內部網路環境、系統存取、密碼管理與人員權限進行全面的重新規劃與防護升級。調整範圍涵蓋了資訊機房、核心資通系統、資安防護設備以及網路監控設備。 (A) 定期辦理社交工程防範演練、系統回復與災難復原演練，確保系統在遇到重大災害時能順利回復正常運作 (B) 在企業網路邊界部署次世代防火牆，各分公司透過 VPN 建立加密連線，並配置備援防火牆與雙線路提升邊界服務可用性 (C) 資訊機房實施門禁並採雙因子管制、網路實施網路隔離、伺服器端安裝端點回應系統，並對核心系統內的敏感資料進行加密 (D) 將核心系統委由具完善門禁與監控機制的機房業者代管，並以業者的實體安全措施及營運稽核結果作為系統存取安全的參考依據之一

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
B	15. 【題組 2】情境如附圖所示，作為內部網路架構調整的核心項目之一，公司計畫在資訊機房與辦公區域實施一套網路准入與設備辨識系統。當設備嘗試連接調整後的核心資通系統或網路監控設備時，該系統會進行身分確認與安全性合規檢查。下列有關此系統的管理實務敘述，何者錯誤？ 「飛遜科技股份有限公司」目前正進行一項大規模的內部網路架構調整。為了因應企業數位轉型並強化整體資安防禦能力，資安團隊必須針對新一代的內部網路環境、系統存取、密碼管理與人員權限進行全面的重新規劃與防護升級。調整範圍涵蓋了資訊機房、核心資通系統、資安防護設備以及網路監控設備。 (A) 系統可以結合 802.1X 協定，對嘗試連網的設備進行身分驗證與授權 (B) 系統可整合設備辨識與使用者角色，並能由網路存取控制政策配置其網路區域及核心應用系統內的功能與資料加解密機制 (C) 在組織環境下，系統可根據連接設備的角色（如運維人員終端、訪客、網路監控設備）將其動態分派到不同的 VLAN (D) 透過持續監控，系統可以發現原本合規的伺服器或終端在連網後是否轉變為不合規狀態

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
AC	16. 【題組 2】情境如附圖所示，在重新設計遠端登入網路監控設備與核心資通系統的存取機制時，團隊決定採用一種能結合「環境因素、主體與客體特徵」的動態權限決策機制，並要求所有管理連線必須進行傳輸加密，同時對資安防護設備的金鑰管理實施嚴格規範。依據上述架構與資安管理實務，下列哪些敘述是正確且合規的？（複選） 「飛遜科技股份有限公司」目前正進行一項大規模的內部網路架構調整。為了因應企業數位轉型並強化整體資安防禦能力，資安團隊必須針對新一代的內部網路環境、系統存取、密碼管理與人員權限進行全面的重新規劃與防護升級。調整範圍涵蓋了資訊機房、核心資通系統、資安防護設備以及網路監控設備。 (A) 動態權限機制應允許系統結合「連線者角色、存取時間、來源 IP、設備安全性合規狀態」等多種條件進行動態綜合決策 (B) 管理連線採用 TLS 1.3 時，可將設備憑證的私鑰同步部署至各管理終端，使連線雙方使用相同私鑰完成身分驗證與通道建立 (C) 管理連線的加密應採用 TLS 1.3 協定，且資安防護設備內加解密金鑰的產製與儲存，應使用專門的硬體安全模組（HSM） (D) 管理流量可使用 AES-256 保護，並由連線雙方各自使用其公開金鑰執行工作階段資料的加解密，以兼顧傳輸效率與身分驗證
D	17. 在設計零信任架構（ZTA）時，資安團隊欲強化身分治理與管理。在不影響營運效率的前提下，下列何種授權機制最能滿足「動態最小權限」的設計原則？ (A) 給予所有中階以上主管永久性的管理員權限，以便在緊急狀況下能快速排除系統故障 (B) 強制實施基於角色的存取控制（RBAC），並凍結所有角色的權限變更，直到年度審查完成 (C) 採用靜態存取控制清單（ACL），明確列出每位員工可存取的 IP 位址與連接埠 (D) 基於屬性的存取控制（ABAC），結合即時風險評分與使用者環境脈絡進行授權判斷

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
B	18. 某金融科技公司的行動 App 後端採用 RESTful API 架構。近期發生一起攻擊事件，攻擊者透過修改 API 請求中的 ID 參數（如/api/users/123 改為/api/users/456），成功存取了其他用戶的個資。請問此漏洞屬於下列何者？且應在架構上實施何種檢核機制來防禦？ (A) 漏洞：Mass Assignment；對策：在程式碼中明確定義允許接收的參數白名單 (B) 漏洞：Broken Object Level Authorization (BOLA)；對策：驗證請求者 ID 與資源擁有者 ID 是否一致 (C) 漏洞：Broken Authentication；對策：強制啟用多因子驗證 (MFA) (D) 漏洞：Security Misconfiguration；對策：隱藏 API 錯誤訊息並關閉除錯模式
B	19. 某製造企業使用 AI 視覺識別模型進行產品瑕疵偵測，模型由外部供應商交付。資安團隊懷疑供應商在訓練資料中植入資料投毒攻擊 (Data Poisoning Attack)，導致特定類型瑕疵品被系統性誤判為合格出貨。依據 NIST IR 8596《Cyber AI Profile》(2025 年 12 月)，下列哪一項分析最正確地說明此攻擊的特性與應對架構？ (A) 資料投毒屬推論執行階段的對抗性攻擊，應在 AI Agent 輸入介面部署語義過濾器，攔截異常輸入以阻止模型被操控 (B) 此攻擊植入於訓練階段，執行期安全掃描無法偵測，應從訓練資料來源管控、完整性驗證及供應商溯源文件三層次防護 (C) 資料投毒的影響固著於模型訓練結果，模型部署後其決策邊界已固定，持續的推論行為監控對偵測此類攻擊幫助有限 (D) 事後針對訓練資料儲存環境強化實體與邏輯存取控制，限制非授權人員接觸原始資料集，使供應商無法植入惡意訓練樣本
AC	20. 為了消除密碼相關的攻擊向量（如撞庫攻擊、釣魚），企業擬推動「無密碼登入」。在選擇技術標準與架構時，下列哪些敘述是正確且安全的實務方向？（複選） (A) 採用 FIDO2/WebAuthn 標準，利用公開金鑰加密機制取代共用密碼 (B) 使用簡訊 OTP (SMS OTP) 作為唯一的無密碼驗證手段 (C) 整合 Passkeys (通行密鑰) 技術，允許私鑰在使用者信任的裝置生態系（如 iCloud Keychain, Google Password Manager）中同步 (D) 依然保留傳統密碼作為備援，且不限密碼複雜度，以免使用者忘記

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
C	21. 【題組 3】情境如附圖所示。在此事件中，攻擊者利用的是供應鏈中的哪一個環節？傳統的靜態應用程式安全測試（SAST）為何可能無法偵測此類威脅？下列描述何者最「不」適切？ 一家知名電子商務公司採用全自動化的 CI/CD 流水線發佈應用程式。某日，開發團隊引入一個開源 npm 套件處理日期格式。然而，該套件維護者帳號遭駭，駭客上傳包含惡意挖礦程式的新版本(v2.0.1)。CI/CD 流水線在自動建置(Build)過程中拉取了此惡意版本，並成功通過基本單元測試，最終部署到生產環境 Kubernetes 叢集中。數小時後，雲端帳單暴增，且系統回應變慢。 (A) 環節：原始碼儲存庫 (Source Code Repository)；原因：SAST 可能無法掃描第三方函式庫的二進位碼 (B) 環節：相依性管理 (Dependency Management)；原因：SAST 主要分析自家撰寫的程式碼邏輯，而非第三方套件的完整行為 (C) 環節：執行環境 (Runtime)；原因：SAST 只能在測試環境運作 (D) 環節：容器映像檔儲存庫 (Container Registry)；原因：SAST 可能無法支援 Docker 映像檔格式
A	22. 【題組 3】情境如附圖所示。為了在惡意套件進入建置流程前就將其阻斷，下列何種架構設計最能兼顧安全性與實務效益？ 一家知名電子商務公司採用全自動化的 CI/CD 流水線發佈應用程式。某日，開發團隊引入一個開源 npm 套件處理日期格式。然而，該套件維護者帳號遭駭，駭客上傳包含惡意挖礦程式的新版本(v2.0.1)。CI/CD 流水線在自動建置(Build)過程中拉取了此惡意版本，並成功通過基本單元測試，最終部署到生產環境 Kubernetes 叢集中。數小時後，雲端帳單暴增，且系統回應變慢。 (A) 建立私有的套件代理伺服器 (Artifact Repository，如 Nexus/Artifactory)，並配置「隔離區」策略，新版本套件需經掃描與數日觀察期後才開放拉取 (B) 在防火牆封鎖所有連往 npmjs.com 的流量，強制開發團隊自行重新開發所需功能 (C) 增加單元測試的覆蓋率至 100%，確保所有功能邏輯都被驗證 (D) 僅允許開發人員在本地電腦下載套件，確認無毒後再手動上傳至 CI 伺服器

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
D	23. 【題組 3】情境如附圖所示。假設惡意容器已在 Kubernetes 中啟動，下列何種「執行期 (Runtime)」防禦機制能最快發現並阻斷異常的對外連線 (C2 連線或礦池連線)？ 一家知名電子商務公司採用全自動化的 CI/CD 流水線發佈應用程式。某日，開發團隊引入一個開源 npm 套件處理日期格式。然而，該套件維護者帳號遭駭，駭客上傳包含惡意挖礦程式的新版本 (v2.0.1)。CI/CD 流水線在自動建置 (Build) 過程中拉取了此惡意版本，並成功通過基本單元測試，最終部署到生產環境 Kubernetes 叢集中。數小時後，雲端帳單暴增，且系統回應變慢。 (A) 啟用容器的自動重新啟動策略 (Restart Policy: Always) (B) 每週定期進行滲透測試 (C) 使用雲端廠商提供的 DDoS 防護服務 (D) 在 K8s 叢集內實施網路策略 (Network Policies)，採「白名單」模式，預設拒絕所有未經定義的對外連線 (Egress Traffic)
ABD	24. 【題組 3】情境如附圖所示。針對此事件，資安長決定重新檢視 CI/CD Pipeline 的安全性。根據 SLSA (Supply-chain Levels for Software Artifacts) 框架，下列哪些措施有助於確保建置過程的安全性？ (複選) 一家知名電子商務公司採用全自動化的 CI/CD 流水線發佈應用程式。某日，開發團隊引入一個開源 npm 套件處理日期格式。然而，該套件維護者帳號遭駭，駭客上傳包含惡意挖礦程式的新版本 (v2.0.1)。CI/CD 流水線在自動建置 (Build) 過程中拉取了此惡意版本，並成功通過基本單元測試，最終部署到生產環境 Kubernetes 叢集中。數小時後，雲端帳單暴增，且系統回應變慢。 (A) 服務建置過程必須是短暫且存在隔離的環境，避免遭持續性植入後門 (B) 所有的建置輸出物 (Artifacts) 必須由建置服務自動簽章 (Provenance)，證明「什麼內容」由「哪個系統」在「何時」建置 (C) 開放所有開發人員擁有 CI/CD Pipeline 配置檔的寫入權限，以利快速除錯 (D) 確保建置腳本 (Build Script) 本身受到版本控制與程式碼審查保護
C	25. 邊緣運算 (Edge Computing) 將資料處理從中心雲端推向網路邊緣的設備端，這帶來了新的安全挑戰。下列何者是邊緣運算最獨特的資安風險？ (A) 網路核心骨幹的頻寬不足問題 (B) 資料在中心雲端進行大規模運算時的隱私問題 (C) 廣泛分佈且缺乏實體保護的邊緣節點，更容易遭受竄改與攻擊 (D) 中心雲端的資料中心可能遭受實體入侵

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
A	26. 某金融機構採用混合雲架構，針對雲端服務提供者與客戶間的「共用責任模型(Shared Responsibility Model)」，在 SaaS 模式下，下列何項資安責任明確屬於客戶端（企業本身）必須負責的範疇？ (A) 設定身分存取管理策略與資料的分類分級保護 (B) 確保底層實體資料中心的門禁管制與電力備援 (C) 管理雲端網路基礎設施的實體路由器與交換器 (D) 維護虛擬化層（Hypervisor）的安全修補程式更新
B	27. 一家金融機構正在進行年度風險評估，特別針對「生成式 AI 導入開發流程」此一新興議題。考量到委外開發之 AI 模型可能產出帶有安全漏洞的程式碼（如：不安全的資料庫查詢語法），此風險應歸類於下列何種類型，並應採取何種處理策略最為適切？ (A) 法律合規風險；應透過購買網路保險來完全轉移 (B) 供應鏈安全風險；應透過在持續整合與部署 CI/CD 流程中整合安全測試工具來減輕 (C) 人力資源風險；應透過解僱使用 AI 的員工來消除 (D) 實體安全風險；應透過加強機房門禁來規避
ABD	28. 企業評估將核心資料庫遷移至公有雲。為了符合 NIST 風險管理框架中「持續監控（Monitor）」步驟的要求，下列哪些措施是必須執行的？（複選） (A) 持續監控雲端組態設定（CSPM），確保未發生錯誤配置（Misconfiguration） (B) 定期審查雲端服務提供者的 SOC 2 或 ISO 27001 稽核報告 (C) 僅在系統上線前進行一次性的弱點掃描與滲透測試 (D) 建立自動化機制，當偵測到未授權的變更時發出告警或自動修復

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
A	29. 【題組 4】情境如附圖所示，資安團隊在為新導入的「AI 網路行銷數據分析系統」進行風險識別時，需要釐清各個安全要素。關於該系統的「威脅」、「弱點」與「風險」三者之間的關係，下列敘述何者最正確？ 「第一等電商行銷公司」目前正進行一項大規模的內部組織架構與資訊設備之調整變更。由於本次調整範圍涵蓋了擴大行銷分析部門，並導入 AI 服務進行網路行銷數據的分析與應用，過程中也大幅度的更新了包含資訊機房、核心資通系統、網路設備等資訊資產。公司的資安團隊必須在架構與變更前，針對整體基礎設施進行全面的資產價值鑑別、風險評鑑與處理之評估事宜，作為後續配置資安防護預算與應變計畫的依據。 (A) 當威脅可能利用系統、流程或人員上的弱點，並對資訊資產造成損害時，即形成須評估其發生可能性及影響程度的風險 (B) 採用高階網路設備並配置充分防護資源後，應依防護措施的規劃完整度判定實際剩餘風險，並據以確認是否低於可接受門檻 (C) 系統若存在尚未修補的軟體漏洞，須將該弱點直接視為應處置的風險，並以漏洞的技術嚴重程度作為整體風險等級 (D) AI 系統的弱點是可能對資訊資產造成損害的攻擊來源或事件，威脅則是系統設計、設定或管理上的缺陷，兩者結合後形成風險

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
A	30. 【題組 4】情境如附圖所示，在評估擴大後的「行銷分析部門」與新型「資訊機房」遭遇實體破壞（如機房火災或電力中斷）的風險時，團隊正在討論如何訂定風險的優先順序。下列哪一個組合最適合用來完整定義一個風險事件的「風險等級」？ 「第一等電商行銷公司」目前正進行一項大規模的內部組織架構與資訊設備之調整變更。由於本次調整範圍涵蓋了擴大行銷分析部門，並導入 AI 服務進行網路行銷數據的分析與應用，過程中也大幅度的更新了包含資訊機房、核心資通系統、網路設備等資訊資產。公司的資安團隊必須在架構與變更前，針對整體基礎設施進行全面的資產價值鑑別、風險評鑑與處理之評估事宜，作為後續配置資安防護預算與應變計畫的依據。 (A) 該風險事件在過去電商行業發生的「可能性（機率）」與其事件發生後對組織造成的「損害程度（衝擊度）」 (B) 受影響資訊資產的「價值等級」，以及現行安全控制措施的建置與執行「成熟度」 (C) 關鍵業務服務的「復原時間目標」，以及組織可容忍的「資料損失與中斷時間」 (D) 相關威脅來源的「活動能力」，以及資訊系統弱點的技術「嚴重程度與可利用性」

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
B	31. 【題組 4】情境如附圖所示，資安團隊正試圖透過計算，評估核心資通系統若遭遇外部勒索軟體攻擊，導致 AI 行銷數據中斷的「年度預估損失金額」。已知該 AI 行銷數據系統與相關核心資產的總價值為新台幣 2,000 萬元。根據情境分析，一旦遭遇勒索軟體成功加密，系統將面臨 30% 的損失（包含營運中斷損失、品牌商譽受損與資料復原成本）。此外，評估該種攻擊在整體架構變更期間，發生的頻率大約為每 4 年發生 2 次。請問該系統因勒索軟體帶來的「年度預期損失金額」應為多少？ 「第一等電商行銷公司」目前正進行一項大規模的內部組織架構與資訊設備之調整變更。由於本次調整範圍涵蓋了擴大行銷分析部門，並導入 AI 服務進行網路行銷數據的分析與應用，過程中也大幅度的更新了包含資訊機房、核心資通系統、網路設備等資訊資產。公司的資安團隊必須在架構與變更前，針對整體基礎設施進行全面的資產價值鑑別、風險評鑑與處理之評估事宜，作為後續配置資安防護預算與應變計畫的依據。 (A) 1200 萬元 (B) 300 萬元 (C) 600 萬元 (D) 150 萬元

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
AB	32. 【題組 4】情境如附圖所示，配合本次大規模的組織調整與 AI 服務導入，資安團隊必須向公司高階管理階層報告風險評鑑結果與對應的四種風險處置策略（風險規避、風險轉移、風險降低、風險接受）。關於這些策略在新架構環境下的實務應用，下列哪些敘述是正確且合規的？（複選） 「第一等電商行銷公司」目前正進行一項大規模的內部組織架構與資訊設備之調整變更。由於本次調整範圍涵蓋了擴大行銷分析部門，並導入 AI 服務進行網路行銷數據的分析與應用，過程中也大幅度的更新了包含資訊機房、核心資通系統、網路設備等資訊資產。公司的資安團隊必須在架構與變更前，針對整體基礎設施進行全面的資產價值鑑別、風險評鑑與處理之評估事宜，作為後續配置資安防護預算與應變計畫的依據。 (A) 評估發現某項第三方 AI 數據分析工具存在無法修補且可能造成客戶個資外洩的重大缺陷，因此取消導入該工具並改採其他合規方案，此作法屬於「風險規避」的策略 (B) 實施網路設備的區域隔離與防護佈署後，AI 系統的預期年度損失由 300 萬元降為 15 萬元，控制措施實施後仍然存在的風險，在管理上被稱為「剩餘風險」 (C) 為了降低核心資通系統遭受大規模網路流量攻擊（DDoS）導致電商服務中斷的衝擊，團隊向保險公司投保了專門的資安險，這在風險管理上屬於「風險降低」 (D) 經高階管理階層針對某一低風險事件（如特定公開行銷網頁的輕微非預期變更）核准採取「風險接受」策略，若持續維持既有控制措施並監控相關風險指標，該項處置應歸類為「風險降低」，而非「風險接受」
C	33. 某科技公司因資安人才短缺，難以維持一個龐大的內部資安維運團隊。為了在預算和人力有限的情況下最大化防禦效益，下列何項投資決策最為務實？ (A) 要求所有開發人員輪流擔任一週的資安工程師 (B) 購買市面上最昂貴的次世代防火牆（NGFW） (C) 優先採購託管式偵測與回應（Managed Detection and Response, MDR）服務 (D) 投入所有預算開發自有的人工智慧防禦系統

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
D	34. 某製造業工廠欲將一組運行 Windows XP 的關鍵舊式機台連網以收集數據，但該系統已無法更新修補程式。在無法汰換設備的情況下，下列何項「補償性控制措施（Compensating Control）」最為適切？ (A) 安裝市售最新版多種防毒軟體，並開啟即時雲端掃描功能 (B) 接受此風險，並增加弱點掃描頻率至每小時一次 (C) 為該機台購買高額資安保險，將勒索軟體攻擊的財務風險轉移 (D) 實施嚴格的網路微切分，將機台置於獨立 VLAN 並僅開放特定 IP 與連接埠
B	35. 針對軟體供應鏈攻擊（如 Log4j 事件），企業決定導入軟體物料清單（SBOM）。請問 SBOM 在風險處理流程中，主要強化的資安韌性階段為何？ (A) 轉移（Transfer）：將漏洞修補責任完全轉嫁給開源社群維護者 (B) 識別（Identify）：能快速定位受漏洞影響的資產範圍，縮短曝險時間 (C) 嚇阻（Deter）：透過法律聲明嚇阻駭客挖掘開源軟體漏洞 (D) 復原（Recover）：能自動修復受損的二進位檔案與資料庫
ABC	36. 資安團隊偵測到內部發生「特權帳號濫用」的高風險事件。為了長期降低此類風險，下列哪些管理與技術控制措施應納入改善計畫？（複選） (A) 實施最小權限原則，僅在需要時授權 (B) 導入使用者與實體行為分析系統，建立行為基線以偵測異常 (C) 強制所有特權操作必須進行全程側錄以便事後稽核 (D) 允許特權帳號共用，以便在緊急狀況下多位管理員能互相支援
A	37. 【題組 5】情境如附圖所示。A 公司使用 LLM（Large Language Model）進行文字語言解析，採用線上的 AI 服務商之 API 訂閱方式，請問在風險識別的部份，下列何者較「不」適切？ AI 運算的使用是目前全球發展的趨勢，在運用上包含雲端 AI 運算、API、自建落地 AI 運算環境等，各有不同的優勢與缺點，在資訊安全面向亦伴隨著風險接觸面而有不同的風險產生與處置方式。A 公司透過上述綜合之 AI 運算模式提供線上客服及數據服務，請試著幫忙回答以下風險管理問題。 (A) 可將包含個人資料的內容傳送至線上 API (B) 先進行資產盤點後再進行風險識別 (C) AI 回應內容不得含公司機密商業資訊 (D) 未分類分級的資料應該避免傳輸到雲端

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
D	38. 【題組 5】情境如附圖所示。A 公司使用 LLM（Large Language Model）進行文字語言解析，採用本地部署的 AI 運算方式，針對演算法模型的安全描述，下列何者較「不」適切？ AI 運算的使用是目前全球發展的趨勢，在運用上包含雲端 AI 運算、API、自建落地 AI 運算環境等，各有不同的優勢與缺點，在資訊安全面向亦伴隨著風險接觸面而有不同的風險產生與處置方式。A 公司透過上述綜合之 AI 運算模式提供線上客服及數據服務，請試著幫忙回答以下風險管理問題。 (A) 可能有被逆向工程反推演算法模型的風險 (B) 可以透過檢核輸入資料，以過濾對演算法模型的攻擊 (C) 必須注意演算法模型被偷竊的風險 (D) 演算法已經編譯成可執行程式，可避免被逆向工程反推演算法模型的風險
D	39. 【題組 5】情境如附圖所示。A 公司使用 LLM（Large Language Model）進行文字語言解析，面對攻擊者使用多種語言或以 Base64、表情符號（emoji）等方式編碼惡意指令意圖攻擊及控制 AI 運算功能，下列何種預防措施「不」適當？ AI 運算的使用是目前全球發展的趨勢，在運用上包含雲端 AI 運算、API、自建落地 AI 運算環境等，各有不同的優勢與缺點，在資訊安全面向亦伴隨著風險接觸面而有不同的風險產生與處置方式。A 公司透過上述綜合之 AI 運算模式提供線上客服及數據服務，請試著幫忙回答以下風險管理問題。 (A) 限制模型行為，強制模型嚴格遵守上下文限制 (B) 記錄所有輸入資料，並對高風險動作要求人工審核 (C) 明確指定輸出格式，要求詳細的推理過程與來源引用 (D) 透過網路防火牆進行風險轉移、風險分擔

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 08 月 22 日

答案	題目
AC	40. 【題組 5】情境如附圖所示。A 公司使用 LLM（Large Language Model）進行文字語言解析，面對系統提示詞洩漏（System Prompt Leakage）的風險，下列哪些事項需要特別留意？（複選） AI 運算的使用是目前全球發展的趨勢，在運用上包含雲端 AI 運算、API、自建落地 AI 運算環境等，各有不同的優勢與缺點，在資訊安全面向亦伴隨著風險接觸面而有不同的風險產生與處置方式。A 公司透過上述綜合之 AI 運算模式提供線上客服及數據服務，請試著幫忙回答以下風險管理問題。 (A) 應用程式的系統提示詞可能洩露本應保持機密的敏感資訊或功能 (B) 使用者可任意、大量提出遷移要求 (C) 即使精確字詞未被揭露，攻擊者透過與系統互動、傳送訊息並觀察結果，幾乎可推斷出系統提示詞中存在的許多防線和格式限制 (D) 攻擊者大量且持續地對 LLM API 發送密文請求

《以下空白》